

第二輪深入 Code Review 與更新清單

日期：2026-10-03 (台灣)。固定程式版本：`e66c6267dec81ecee45b2df7fb73ffd86fc3628a`。

依業主要求，由主代理與三位代理並行：權限 / 交易、背景工作 / 備份、使用文件。這是程式與證據審查，沒有修改業務邏輯、升級依賴或部署正式站。

審查結論

新增 8 項：2 個 P1、6 個 P2；上輪 10 項尚未修復。優先處理資料公開投影、上傳撤權、外部目的及未知結果，再修交接、輪詢、恢復與前端錯誤處理。

本輪 GitHub 總覽 #52 · 上輪總覽 #43 · 全部歷史追蹤 #32

方法、覆蓋與限制

範圍	本輪方法	結論邊界
登入、權限、附件與投影	閱讀 API / 角色政策；TestClient 注入撤權時序；交接全流程合成驗證	不使用同事真實 session；未聲稱 Drive 已越權寫入
Worker / 原生審批	檢視授權、回執、冷卻、批次上限；SQLite 模擬 101 件、30 輪	遠端 I/O mock，不證明實際 Lark 延遲或批准結果
來源 / SOP / 業務流程	覆核前輪發現與政策；重跑既有缺陷斷言	不把歷史日報免核對解讀為配對成功
備份恢復	閱讀 snapshot / offsite / schedule；有效 hash 合成 ZIP 注入 DB 失敗	沒有正式 DB 恢復、刪檔或金鑰變更
API 與資料量	非物件 JSON、SQL statement 監聽、前端實際 api.ts 編譯後測試	查詢全量已證實，但未宣稱百萬筆效能數值
相依套件	npm 官方 registry audit + 維護者安全公告交叉核實	主要為 dev server；不是正式靜態網站已被入侵的證據
前端及文件	隔離 Demo 真實瀏覽器拍攝六張操作圖，資料流圖四種尺寸檢查	截圖是示範資料；普通員工正式操作仍待驗收

完整回歸：1,368 passed、1 failed，402.35 秒。失敗仍是 #42：模組收集時建立 now()+5 minutes，整套跑逾五分鐘後已不是未來。前輪同模組單獨跑 18 passed。本輪沒有為了得到全綠而跳過它或更改測試。

合成證據：主代理舊 8 項 + 本輪 API / 還原 / 稽核 4 項共 12 passed；權限 / 交接代理 2 passed；poller 代理 1 passed。另以前端實際 api.ts 進行 Node 合成測試，確認 HTTP200 非JSON成功 resolve。這些 pass 是「成功重現缺陷」，不是「缺陷已修好」。

本機為 Python3.11.5、SQLAlchemy1.4.39、SQLite；正式映像為 Python3.12 與鎖定依賴。未新跑正式 PostgreSQL 整合、活體 Lark 寫入、真人雙席或完整滲透測試。不能以本報告保證零漏洞、全面正式驗收或每一行都經形式證明。

前端正式建置：通過 (44.3 秒) 。

新增問題總表

等級	問題	追蹤
P1	附件上傳鎖內仍用舊身分，降權後在途請求可新增附件	#44
P2	交接 from_id/to_id 被錯誤投影，接手人看不到接受操作	#45
P2	原生審批固定輪詢順序使新申請長期排不到查回	#46
P2	還原交易失敗留下空目錄，清除檔案後仍無法重試	#47
P2	工作區切換與試行複製未驗證 JSON 物件，陣列輸入回500	#48
P2	稽核 API 分頁只切回應，全量讀取與掃描歷史資料	#49
P2	前端 API 將 HTTP200 非JSON回應當成功資料回傳	#50
P1	更新 Vite 與 esbuild：目前開發工具鎖版含已知漏洞	#51

新增問題的具體證據

1. [P1] 附件上傳鎖內仍用舊身分，降權後在途請求可新增附件

[GitHub #44](#)

位置

[backend/app.py:474](#)

證據

具公司普通業務備援 grant 的管理員，在 identity 驗證後、UploadFile.read 期間被降為 member 並 manager_revoked=true (active 仍 true)。真實 TestClient/SQLite 重現第一次上傳200並寫入附件metadata及file job，下一個新請求403。authorize_upload閉包仍引用舊user，鎖內load雖已讀新profile卻沒有使用。

影響與限制

撤權後在途上傳仍可變更資料；未證實Worker會繼續遠端Drive寫入，勿將本地入列等同外送成功。

更新及驗收

鎖內取最新actor，is_pm/is_owner、queue/event一律用它；撤權時403、無metadata/job且清暫存檔。

相關：#19、#43。

2. [P2] 交接 from_id/to_id 被錯誤投影，接手人看不到接受操作

GitHub #45

位置

backend/workspace_projection.py:103

證據

真實apply_operation：PM提出u-field→u-agent交接、manager核准、保存DB。接手人GET /api/workspace的handover_requests為空；同人已知ID直接handover_accept能成功。operations.py:794寫from_id/to_id，投影卻以principal_id/delegate_id/requested_by過濾；Operations.tsx:63只能由回傳列表呈現接受按鈕。

影響與限制

主管代提的一般交接雙方可能看不到紀錄，導致UI流程卡住；不是後端拒絕合法接受。

更新及驗收

handover與delegation各用正確schema；測試原負責人、接手人、PM、管理員及無關人員可見性與接受流程。

相關：#21、#24、#43。

3. [P2] 原生審批固定輪詢順序使新申請長期排不到查回

GitHub #46

位置

backend/native_poller.py:138

證據

真實SQLite/run_due/_claim/store合成測試：前100筆executed加第101筆pending，模擬30輪、每輪30秒，全部300次觀察都是前100筆（各3次），第101筆從未取得native_poll_status。候選固定順序、每輪10件、每件300秒冷卻，且歷史終態仍佔名額。mock僅遠端I/O、policy、receipt commit；沒有真正呼叫Lark。

影響與限制

新變更、跳過或財務審批可能長期停留舊狀態；不是越權核准。約100件是30秒週期條件的例子，慢I/O可能在更少歷史件數時發生。

更新及驗收

以最久未查/未查過優先或持久游標公平輪詢；歷史終態降低頻率但保留必要撤銷核驗。驗收超過批次容量時新單於有界輪數被處理。

相關：#1、#21、#43。

4. [P2] 還原交易失敗留下空目錄，清除檔案後仍無法重試

[GitHub #47](#)

位置

[scripts/backup_restore.py:126](#)

證據

合成有效hash ZIP含附件及重複workspace主鍵；restore先寫附件後DB insert失敗。except移除已寫檔案，留下uploads/synthetic空目錄；再次呼叫立即ValueError「Restore upload directory must be empty」。SQLite隔離斷言通過。

影響與限制

DB失敗或其他回滾後無法直接以同目標重試，增加災難恢復阻力。測試刻意用無效資料列觸發交易失敗，不宣稱正常backup會產生重複主鍵。

更新及驗收

追蹤本次新建目錄，回滾時逆序移除仍空的目錄；不可刪既有或非空路徑。驗收DB錯誤後資料與附件目標仍可安全重試。

相關：#3、#23、#43。

5. [P2] 工作區切換與試行複製未驗證 JSON 物件，陣列輸入回500

[GitHub #48](#)

位置

[backend/app.py:682](#)

證據

已登入manager的隔離TestClient向 /api/workspace/switch 與 /api/pilot/copy POST []，兩個端點都500。request.json()後直接body.get，缺少物件型別驗證。兩項合成測試通過。

影響與限制

使用者輸入錯誤變成未處理伺服器例外；未證實資料修改或權限繞過。其他原生入口亦應盤點同類模式，不能把未測端點都宣稱已重現。

更新及驗收

共用嚴格JSON解析/Pydantic模型；非物件、損壞JSON、null及缺欄位均穩定4xx且無狀態變更。

相關：#19、#25、#43。

6. [P2] 稽核 API 分頁只切回應，全量讀取與掃描歷史資料

GitHub #49

位置

backend/app.py:375

證據

合成加入240筆audit，GET /api/audit?limit=1回一筆，但SQL監聽確認action_audit SELECT無LIMIT，程式先list(db.scalars(...))再逐筆篩選與切片。/api/admin/audit/history亦使用全量迴圈。

影響與限制

每次小分頁仍隨歷史總量消耗記憶體與CPU。已證實查詢結構，尚未進行百萬筆壓力測試，不虛構延遲或OOM數字。

更新及驗收

將可見性/案件/角色條件下推，採游標或有界分批取得；不得先LIMIT再Python過濾而漏項/洩漏。驗收大量歷史下bounded queries與頁面完整一致。

相關：#23、#25、#43。

7. [P2] 前端 API 將 HTTP200 非JSON回應當成功資料回傳

GitHub #50

位置

frontend/src/api.ts:4

證據

使用esbuild編譯實際api.ts並注入fetch→Response("proxy fallback",{status:200})。api Promise成功resolve為{detail:"服務回應格式不正確，請稍後再試。"}，未reject。caller以Workspace等型別接受它，可能在後續渲染或成功回呼出錯。

影響與限制

代理錯誤頁或格式錯誤的200回應失去統一錯誤處理；未宣稱已在正式環境遇到或確定發生資料遺失。

更新及驗收

JSON解析失敗應throw明確錯誤；必要處檢查回應schema。覆蓋200 HTML/空白/損壞JSON、合法JSON及401/403，保留原狀態與草稿。

相關：#24、#25、#43。

8. [P1] 更新 Vite 與 esbuild：目前開發工具鎖版含已知漏洞

GitHub #51

位置

frontend/package.json:8

證據

本輪npm audit（官方registry）回報2個受影響套件：vite high、esbuild moderate。Vite鎖6.0.7，npm提供同主版本6.4.3修正路徑；dev script使用--host 0.0.0.0。官方Vite公告GHSA-fx2h-pf6j-xcff確認<=6.4.2受影響、6.4.3修復；esbuild GHSA-67mh-4ww8-2f99範圍<=0.24.2。

影響與限制

主要是開發伺服器暴露 / 任意來源讀取與Windows路徑邊界；正式Docker提供靜態build，不能據此宣稱正式API已遭利用。P1指開發環境暴露時優先更新。

更新及驗收

評估Vite6.4.3或受維護相容版本、更新package-lock，限制dev bind為127.0.0.1除非明確需要；npm ci/build/audit及UI流程驗收。不要只跑audit fix --force。

官方來源：<https://github.com/vitejs/vite/security/advisories/GHSA-fx2h-pf6j-xcff>
<https://github.com/evanw/esbuild/security/advisories/GHSA-67mh-4ww8-2f99>

相關：#28、#43。

上輪尚未修復的項目

Issue	優先序	待修內容
<u>#33</u>	P1	同步 POST 回傳原始欄位，與 GET 公開投影不一致
<u>#34</u>	P2	人員異動事件含完整私有 profile
<u>#35</u>	P1	正式 Drive 目錄缺少伺服器核定根目錄 / 測試目錄限制
<u>#36</u>	P2	已證明未建立並放棄的審批仍阻擋 SOP 套用
<u>#37</u>	P1	通知成功但本地回執失敗後仍可直接重送
<u>#38</u>	P2	storage.save 遇同類型重複 ID 靜默覆蓋
<u>#39</u>	P2	action 長度與 PostgreSQL audit 欄位不符；實際 PG 尚待覆驗
<u>#40</u>	P2	SOP 停用任務仍計入駕駛艙逾期

Issue	優先序	待修內容
<u>#41</u>	P2	財務確認切案件殘留草稿、節點與佐證 state
<u>#42</u>	P2	OAuth 未來時間測試依賴收集時間，完整回歸誤紅

還有哪些東西要更新

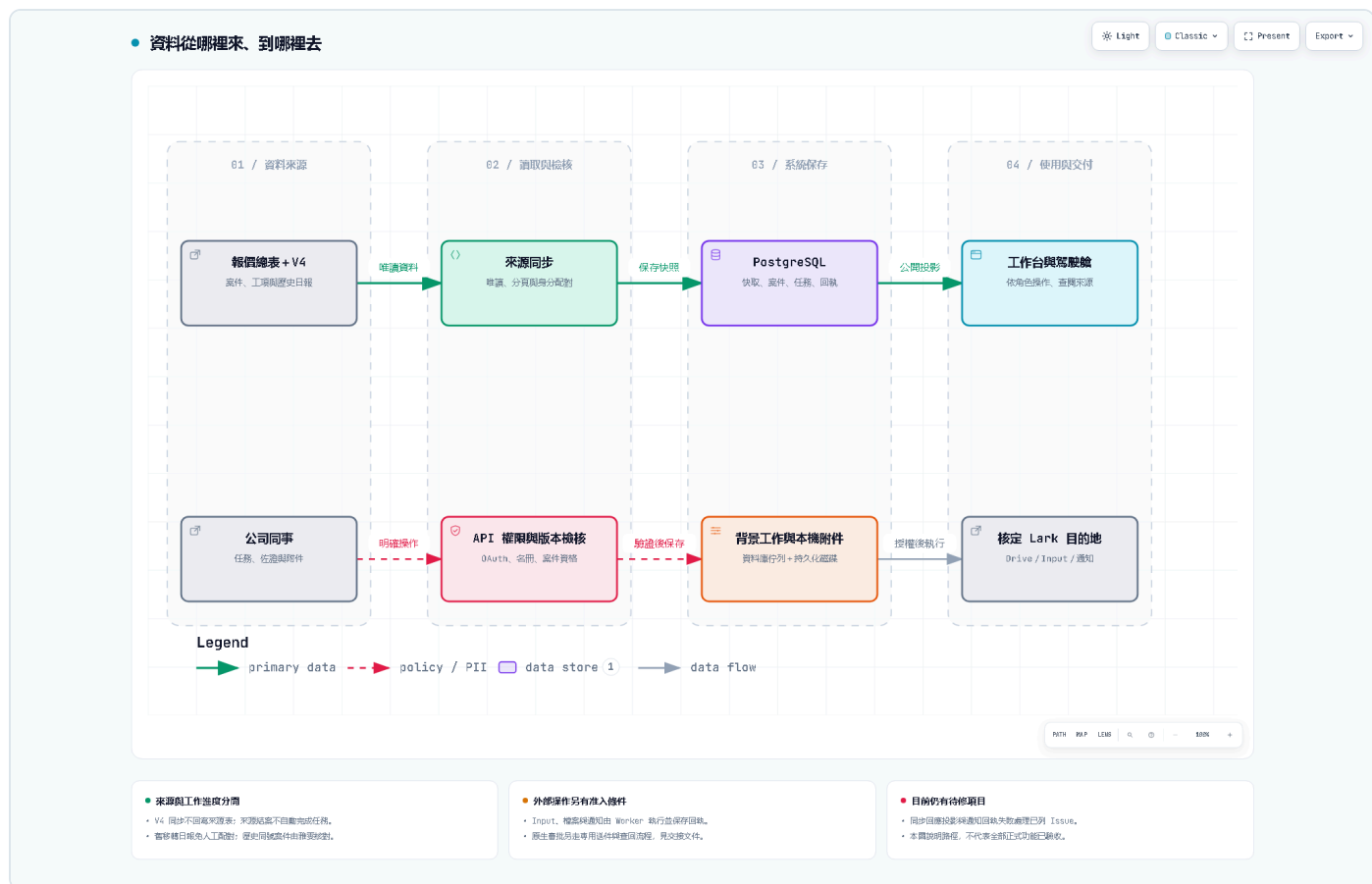
更新範圍	本輪完成	下一步與驗收
交接與使用文件	新增本套圖文、資料流向、最新決策與明確限制	維護者依實際新版本更新，避免只累加歷史紀錄
README 入口	改指向新交接與手冊；修來源讀取身分及舊日報說明	新人按文件可啟動；正式與示範說明一致
歷史日報免核對	追蹤與文件已採最新業主決策	程式尚未區別免核對批次的狀態 / 提示；按來源批次或明確識別套用，不全域忽略未來日報
歷史同號案件	34 組 / 68 筆已私下請雅雯核對	等逐組結論再整理；不按同名直接刪除。公開文件不附真實案件明細
前端依賴	已核實 audit 與修復版本	更新 Vite / esbuild / 鎖檔 · npm ci、build、audit、主要UI流程
測試環境與 CI	說明本機與正式版本差異	Python3.12 + PostgreSQL 同環境；修 #42；新增 CI 阻擋失敗與漏洞掃描
正式外部驗收	保留已有回執且不擴大成功宣稱	真人兩席、普通同事、常態備份、同版24h觀察

依 npm audit，本輪合計 1 high、1 moderate。Vite 6 系列的官方修補版本包含 6.4.3；應先驗證相容更新，再評估是否遷移新主版本，不把「版本較新」當成可以省略回歸的理由。[Vite 維護者公告](#)、[esbuild 維護者公告](#)。

驗收與交付閘門

每個 Issue 修正後：先讓對應反例不再成立，再驗證正常路徑與既有權限。含遠端副作用者須加入成功回應後本地儲存失敗、未知結果、撤權、目的變更與重啟情境。不要以反例測試通過、截圖看起來正常或 HTTP200 當作全流程驗收。

建議發布前紀錄：commit、依賴鎖檔、完整測試結果、前端資產hash、備份回執、staging與正式版本對照、本人操作證據、已知未完成項。若仍有失敗，明列而非從報告省略。



資料流與風險所在路徑

圖中文字為繁體中文，內建檢視器為英文。Archify 九項 artifact checks 通過；四種桌面尺寸的自動瀏覽器檢查通過，並人工檢視最大尺寸圖片。程式檢查、瀏覽器檢查與實際業務驗收是三種不同證據。